

VulnWatch: Domain Verification Lifecycle RFC

VulnWatch · Status: DRAFT · May 2025

Authors: Engineering · Reviewers: Product, Security, Development

Goal

Users must verify domain ownership before VulnWatch can initiate scans. Without verification, any user could scan third-party infrastructure, creating legal liability and abuse risk. This RFC defines the full registration, verification, and status lifecycle.

Token Format

On domain registration, the system issues a unique token:

```
vulnwatch-verify=<32-byte-hex> (256-bit entropy, 72h TTL)
```

The plaintext token is shown once and never logged. Only its SHA-256 hash is stored, scoped to the user-domain pair.

Verification Methods

A — DNS TXT Record

- Add TXT record: `_vulnwatch-verify.example.com` → `"vulnwatch-verify=<token>"`
- System performs a DNS TXT lookup and compares against the stored hash.
- If the record is not yet visible, returns `202 dns_propagation_pending` — not a failure. User is prompted to retry after 15 min. Hard failure only after the 48h propagation window.

B — File Upload

- Place a file at: `https://example.com/.well-known/vulnwatch-verify.txt`
- File must contain only the token string. HTTPS only; up to 3 redirect hops followed.
- 404 or mismatch after 3 retries → `422 verification_failed`.

C — Email Confirmation

- System discovers admin address (`admin@`, `webmaster@`, `hostmaster@`) and sends a one-click link.
- Link is valid for 72h and single-use. Second click returns `410 Gone`.

Domain Status Transitions

- `pending` → Domain registered, token issued, no attempt made.
- `dns_propagation_pending` → DNS method active; record not yet resolvable. Retryable.
- `verification_failed` → Check ran but token mismatch or endpoint unreachable.
- `verified` → Token confirmed. Domain authorized for scans.
- `expired` → 72h TTL elapsed. Re-registration required.

API Endpoints

POST	<code>/api/v1/domains</code>	Register domain, receive token
POST	<code>/api/v1/domains/:id/verify</code>	Trigger verification check
GET	<code>/api/v1/domains/:id/status</code>	Poll current status
DELETE	<code>/api/v1/domains/:id</code>	Revoke registration

The status endpoint is safe to poll at any frequency and is suitable for UI polling and CI pipelines.

Security Considerations

- Rate limit: 10 verify attempts per domain per hour; max 20 unverified domains per user.
- DNS lookups originate from a fixed egress IP range to prevent DNS rebinding.
- A domain verified by one account cannot be re-registered by another until revoked or expired.
- Expired tokens are soft-deleted and purged after 7 days.

Out of Scope

- Wildcard (`*.example.com`) and sub-domain inheritance. Each domain/sub-domain registers independently.
- Automatic re-verification on WHOIS ownership transfer. Delegated org-level verification (future work).

Approvals required from Engineering Lead, Product, and Security before implementation begins.

VulnWatch — Domain Verification Lifecycle RFC

